ФСП · Обратный найм

Платформа обратного найма ИТ-специалистов: кандидат подтверждает грейд тестом, работодатель находит нужную категорию и сам присылает приглашение с вилкой.

Стенд для жюри: адрес выдаётся в материалах сдачи. В шапке есть переключатель демо-персон: кандидат, работодатель, модератор. Регистрация тоже работает.

Гид жюри: шесть шагов

1. **Вход.** На главной выберите демо-персону «Кандидат» в шапке или войдите по почте. Есть и вход через FSP ID, он подтягивает достижения ФСП.
2. **Опрос и грейд.** В кабинете кандидата выберите направление и заявленный грейд.
3. **Экспресс-тест.** Пройдите короткий тест. По итогу кандидат получает категорию «направление × грейд». Экспресс занимает 3–5 минут, полный тест уточняет позицию.
4. **Потребность работодателя.** Переключитесь на демо-персону «Работодатель», создайте потребность или откройте готовую.
5. **Карта и подборка.** На карте видны категории, в подборке кандидаты сгруппированы блоками с пояснениями. В засеве есть кандидат без ФСП выше кандидата с ФСП и слабым тестом.
6. **Приглашение и контакт.** Отправьте приглашение с вилкой, переключитесь на кандидата, примите его и напишите в чат. Контакты открываются только после принятия.

Дальше по желанию: доска найма и оценки, навыки и «Работа с ИИ», «Хочу к вам», задачи компаний, вакансии и отклики, командный найм, модерация, лаборатория.

Четыре числа лаборатории

Раздел «Лаборатория» показывает проверку теста и подбора на синтетических кандидатах, у которых уровень известен заранее. Последний прогон на 3000 кандидатов:

- верные решения теста вдали от порога: 92%;
- повторный тест даёт то же решение: 71%;
- качество подборки nDCG@10: 0.66, у лучшего бейзлайна «ключевые слова стека» 0.33;

- ложные подтверждения при утечке трети банка: 8%, у статичного банка 50%.

Источник чисел: `reports/validation.json`, страница `/lab`.

Что внутри

- **Кандидат.** Регистрация и согласия, резюме вручную или из PDF, адаптивный тест на грейд, навыки и «Работа с ИИ», профиль и условия, приглашения, чат, «Хочу к вам», задачи и вакансии.
- **Работодатель.** Профиль компании и уровень доверия, потребность, подборка блоками с пояснениями, приглашения и квота, доска найма и оценки, карта, командные приглашения, задачи, вакансии, интеграции (ATS).
- **Модератор.** Одна очередь обращений: споры об оценках, жалобы, заявки на L3, возражения по ст. 16.

Документация

- Архитектура
- Механика тестирования
- Механика подбора
- Валидация и результаты
- Интеграции: ФСП, FSP ID, DaData, ATS
- Персональные данные и согласия
- Языковая модель
- Сборка и запуск
- Гид по экранам для жюри
- Безопасность и развёртывание
- Библиотеки и лицензии
- API: openapi.json, ReDoc

Модель угроз описана на странице `/about/threat-model`.

Быстрый старт

Локально: `make devdb`, затем `make seed`, `make api`, `make web`. Через Докер: `make up`. Развёртывание на сервере рядом с другими приложениями описано в `deploy/README.md`. Подробнее: Сборка и запуск.

Архитектура

Компоненты

Стек собран из контейнеров. Наружу смотрит только веб-сервер, остальное живёт во внутренней сети.

Сервис	Роль
`web`	nginx: собранный фронтенд и прокси `/api` и `/mock` на API
`api`	FastAPI: бизнес-логика, два воркера uvicorn
`worker`	тот же образ: письма, напоминания, вебхуки, фоновые прогоны лаборатории
`db`	PostgreSQL 16
`mailpit`	почта для демо
`mocks`	встроенные моки внешних систем, это роуты процесса `api`

```
flowchart LR
  browser["Браузер"] --> web["web: nginx"]
  web -->|/api, /mock| api["api: FastAPI"]
  api --> db[("PostgreSQL")]
  worker["worker"] --> db
  api -.-> llm["LLM по OpenAI-совместимому API"]
  api -.-> fsp["FSP ID и API достижений"]
  api -.-> dadata["DaData"]
  worker -.-> ats["ATS компании, вебхуки"]
```

Внешние системы на схеме пунктиром: без ключа LLM и с включёнными моками продукт работает целиком.

Модульный монолит

Один бэкенд, разделённый по модулям. Модули общаются через сервисный слой и не читают таблицы друг друга.

Модуль	Зона ответственности
`auth`	пользователи, роли, сессии, согласия, привязка FSP ID
`candidates`	профиль, стек, резюме и PDF, условия, блокировки компаний
`assessment`	банк заданий, движок теста, попытки, навыки, «Работа с ИИ»
`fsp`	достижения ФСП, расчёт коэффициента, команды
`employers`	компании, потребности, уровень доверия
`matching`	карта, ранжирование, объяснения, шортлист
`contacts`	приглашения, квоты, чат, сигналы, задачи, вакансии
`hiring`	этапы найма, оценки, калибровка
`moderation`	очередь обращений
`integrations`	outbox, вебхуки, почта, ATS
`llm`	клиент модели, маскирование, проверка фактов
`lab`	симуляции и отчёты

Почему монолит: команда из одного человека и ИИ-агента, слабый сервер и жёсткий срок. Модули с явной границей дают ту же читаемость, что микросервисы, без сети между ними. Подробнее — в `docs/design/2026-10-07-technical-design.md`.

Сквозной сценарий

Шесть шагов гида на уровне запросов.

```
sequenceDiagram
  participant C as Кандидат
  participant A as API
  participant W as Работодатель
  C->>A: вход, опрос, заявленный грейд
  C->>A: попытка теста, ответы, итог
  A-->>C: категория «направление × грейд»
  W->>A: потребность и подборка
  A-->>W: кандидаты блоками с пояснениями
  W->>A: приглашение с вилкой
```

```
A-->>C: приглашение
C->>A: принятие и согласие на передачу контактов
A-->>C: контакты и чат
A-->>W: контакты и чат
```

Ленивые статусы и worker

Всё, что зависит от времени, считается при чтении: истечение приглашения, вступление оценки в силу, автозакрытие попытки. Worker только ускоряет: истечение и напоминания, письма, вебхуки и фоновые прогоны лаборатории. Если worker остановится, продукт продолжит работать. Повторы идемпотентны: уведомления по ключу, доставка вебхуков по паре «эндпоинт и событие».

Данные

Схема описана моделями SQLAlchemy. Диаграмма связей выгружается скриптом:

```
cd backend && uv run python -m tools.er_diagram > ../docs/er.mmd
```

Готовые диаграммы — в `docs/er.mmd`. Инварианты держатся частичными уникальными индексами: одно активное приглашение на пару «потребность и кандидат», одна активная попытка, один активный прогон лаборатории.

Конфигурация

Числа собраны в `backend/app/config/params.py` и переопределяются переменными окружения. Секреты и адреса внешних систем — в `backend/app/config/settings.py`. Хардкод чисел в логике не используется.

Механика тестирования

Грейд даёт только тест

Категория кандидата это связка направления и грейда, и её подтверждает тест. Резюме, стек и достижения ФСП влияют на порядок внутри категории, но не заменяют тест.

Заявленный грейд не понижается принудительно: кандидат может пройти тест на уровень ниже или выше.

Как устроен тест

- **Модель Раша** оценивает скрытую способность θ по ответам. Оценка считается методом EAP на сетке, поэтому результат устойчив к малым выборкам.
- **Фазы.** Сначала идёт решение о грейде. Тест останавливается, когда вероятность подтверждения становится высокой или низкой. Между фазами показывается экран с переходом и предложением продолжить для уточнения позиции.
- **Экспресс.** Короткий режим на 8 заданий. Если результата не хватило, кандидату предлагают продолжить ту же попытку; вернуться можно в течение 72 часов.
- **Таймеры и паузы.** Время считается на открытое задание, между заданиями перерыв не ограничен. Попытка, брошенная без завершения, не засчитывается, и пересдать можно сразу.

Устойчивость к распространению заданий

Единый банк заданий разошёлся бы между кандидатами, а генерация нейросетью под каждого не гарантирует сопоставимую сложность. Поэтому задания генерируются из семейств с вычисляемым ключом:

- у каждого семейства есть генератор, который по seed собирает конкретный вариант: числа и данные каждый раз новые;
- seed выводится из секрета и номера попытки, поэтому прогон воспроизводим, но не предсказуем кандидатом;
- ключ ответа и параметры экземпляра остаются на сервере и на клиент не уходят;
- семейство публикуется, только если на проверочных seed выполнены условия: доля уникальных формулировок не ниже порога и оценка пространства вариантов достаточно велика.

Опираемся на принцип Керкгоффса: код открыт, секретны seed и ответы. Устойчивость проверяется экспериментом «утечка»: часть банка отдаётся как известная, и считается доля ложных подтверждений. На нашей генерации это 8%, у статичного банка 50%.

Дискриминативность и стабильность

Лаборатория считает качество теста на синтетической популяции:

- верные решения вдали от порога: 92%;

- у самого порога: 57%, там решает граница, и для спорного случая предлагается полный тест;
- повторный тест даёт то же решение в 71% случаев, к = 0.33; вдали от порога к близка к 1;
- ложные подтверждения и ложные отказы считаются по грейдам отдельно.

Первоисточник чисел: `reports/validation.json`, страница `/lab`. Подробнее — в `docs/validation.md`.

Банк заданий

- 275 семейств на три направления (Backend, Frontend, Data / Analytics), навыки и «Работу с ИИ».
- Конвейер проверяет каждое семейство: детерминизм, уникальность ключа, ломающиеся входы, пространство параметров. Проверка запускается целью `make bank-check`.
- Экспозиция семейства учитывается отдельно от синтетических прогонов лаборатории.

Навыки и «Работа с ИИ»

- **Навыки.** Шесть заданий подтверждают технологии из стека и отмечают их галочкой в профиле. На грейд навыки не влияют.
- **Работа с ИИ.** Отдельный формат, где ИИ разрешён: кандидат оценивает готовые решения, отмечает ошибку с ломающим входом или просит уточнить требование. Зачёт по точности и по принятым ошибкам с учётом уверенности. В лаборатории считаются три политики, включая «полагаться на второй ИИ».

Смена грейда

Частота смены ограничена кулдаунами: отдельно для перехода вверх, вниз и для навыков. Если применимы несколько правил, действует самое строгое. Достижения ФСП и собеседования кулдауны не сокращают.

Модель угроз

Что ловим и что остаётся, описано на странице `/about/threat-model`: уход со вкладки и вставка текста отмечаются, но тест за это не прерывается; ИИ на другом устройстве

ловится сверкой с ФСП и оценками на собеседованиях, полной защиты без прокторинга нет.

Механика подбора

Категория

Работодатель ищет не по резюме, а по категории: направление и подтверждённый грейд. Внутри категории кандидаты ранжируются по силе подтверждённого профиля.

Подборка под потребность

Потребность описывает, кто нужен: специализация, грейды, обязательный и желательный стек, форматы, вилка и занятость. По ней строится подборка, разбитая на блоки:

- подтверждённые целевые грейды;
- соседние грейды;
- неподтверждённые;
- «почти подходят» с жёсткими конфликтами.

Кандидат попадает ровно в один блок. Неподтверждённый никогда не встаёт выше подтверждённого.

Формула ранжирования

Сила подтверждённого профиля:

```
R = s · (1 + 0.25 · f) · m
```

где `s` это сила теста, `f` коэффициент достижений ФСП, `m` множитель по собеседованиям (от 1 до 1.2, только повышает).

Итоговый балл под потребность:

```
score = Fit · (0.8 + 0.2 · Accept)
```

`Fit` это покрытие стека и нормированная сила профиля, `Accept` это совпадение по вилке, форматам, окну поиска и активности. Формулы и контрольные случаи описаны в `docs/design/2026-10-06-end-to-end-process.md`, раздел 6.

Объяснимость

У каждого кандидата есть строки объяснения: почему он в подборке и чем силён. По раскрытию карточки показывается сводка, чего не хватает, и контрфакт: что изменится при ослаблении условия. Числа и технологии в тексте сверяются с фактами карточки, модель не добавляет того, чего нет.

Достижения ФСП

Достижения поднимают кандидата внутри категории, но не заменяют тест. Учитывается место, уровень старта и роль команды. Онлайн-отборы считаются по одной дисциплине за результат, чтобы кандидат не набирал коэффициент за счёт массовых онлайн-этапов.

«Хочу к вам» и спрос

Кандидат может отметить компанию, тогда он поднимается в её подборках. Отметка действует ограниченное время и тратит квоту квартала. Обратно компания видит анонимный спрос по категории: сколько компаний искали похожих специалистов.

Защита скрытого порога

Порог зарплаты кандидата работодателю не виден. Вилка приглашения обязательна, поэтому подбор не превращается в угадывание. Если вилка не покрывает ожидания, кандидат видит это и может отказаться осознанно.

Как проверяется качество

Лаборатория считает подборку на синтетической популяции со скрытой истиной: nDCG@10, P@10, MRR, отложенную выборку, ablation и парные контрольные случаи, включая «сильный тест без ФСП выше слабого теста с ФСП». Итог на 3000 кандидатах: nDCG@10 = 0.66, у лучшего бейзлайна «ключевые слова стека» 0.33. Числа и разбивки — в `docs/validation.md`.

Валидация и результаты

Отчёт лаборатории от 2026-10-10, популяция 3000 синтетических кандидатов. Источник: `reports/validation.json`, страница `/lab`. Симуляция со скрытой истиной, реальные данные не используются.

Четыре числа

- **Верные решения теста**: 92%. если |θ − порог| ≥ 0.5; у самого порога 57%, там решает граница.
- **Повторный тест даёт то же решение**: 71%. к = 0.33; вдали от порога к → 1.
- **Качество подборки, nDCG@10**: 0.66. 95% ДИ 0.59–0.72; лучший бейзлайн «Ключевые слова стека»: 0.33.
- **Ложные подтверждения при утечке трети банка**: 8%. у статичного банка 50%, у кандидата без доступа к утечке 8%.

Тест

Верных решений всего 79%, вдали от порога 92%, у порога 57%. Повторный тест даёт то же решение в 71% случаев (к = 0.33). Экспресс решает сам в 31% случаев с точностью 91%.

Грейд	N	Ложные подтверждения	Ложные отказы	Длина, сред.	Экспресс
junior	1076	24%	20%	12.6	7.9
middle	968	13%	22%	12.4	7.9
senior	956	17%	21%	12.6	7.9

к по расстоянию до порога: 0.0–0.25: -0.04, 0.25–0.5: 0.19, 0.5–1.0: 0.47, 1.0–∞: 0.97.

Эксперимент «утечка»: раскрыто 30% банка. Ложные подтверждения у нашей генерации 8%, у статичного банка 50%, у кандидата без утечки 8%.

Подбор

Кандидатов 900, потребностей 30, отложенная выборка 9 потребностей.

Ранжирование	nDCG@10	P@10	MRR	nDCG отложенная
Наше ранжирование	0.66	0.39	0.76	0.64
Случайно	0.11	0.03	0.13	0.08
Только тест	0.12	0.04	0.10	0.12
Ключевые слова стека	0.33	0.25	0.39	0.35
Самоописание	0.27	0.14	0.38	0.22
Только ФСП	0.13	0.04	0.14	0.15

Ablation (nDCG@10): без ФСП 0.65, без стека 0.39, без готовности 0.64, без подтверждений 0.66, без блоков 0.52.

Контрольные случаи: - ✓ Сильный тест без ФСП выше слабого теста с ФСП (случай 1) - ✓ Подтверждённые 2 из 3 must выше заявленных 3 из 3 (случай 2) - ✓ Три «ниже» дают m = 1, три «соответствует» дают m ≈ 1.12 (случай 3) - ✓ Добавили must-технологию: кандидат выше - ✓ Добавили ФСП при равном тесте: кандидат выше - ✓ Экспресс и полный тест при равном θ̂ различаются мягко (случай 4)

Правило блоков: каждый кандидат в одном блоке да, неподтверждённый никогда не выше подтверждённого да. Смена города не меняет порядок в 100% случаев, смена псевдонима в 100%.

Справедливость (доля «без ФСП / с ФСП» в топ-10 при равной силе теста): 0.16, 0.51, 0.60. Доля онлайн-отборщиков в топ-10 5% при 5% среди релевантных.

Калибровка и рынок

Экспертный порог смещён на 0.3 логита. Ошибка после калибровки: N=30: 0.30, N=100: 0.16, N=300: 0.11.

Вариант рынка	Приглашений на потребность	Принято	Ниже порога	p95 на кандидата	Качество найма
ours	10.5	65%	22%	4.0	1.47
no_fork_info	10.5	65%	23%	4.0	1.47
no_quota	61.6	70%	12%	6.0	1.37

Вариант рынка	Приглашений на потребность	Принято	Ниже порога	p95 на кандидата	Качество найма
random_order	10.1	79%	14%	2.0	1.00

Проверка модели

- **solver**: согласие моделей deepseek/deepseek-v4.1-flash 100% и openai/gpt-6-luna 95%, заданий 20, подозрительных ключей 0.
- **judge**: выполнено.

«Работа с ИИ»: три политики

Политика	Подтверждено	Точность	Принятые ошибки ИИ	Отклонённые верные	Минут
Принимает всё	0%	55%	100%	0%	1
Только второй ИИ	60%	80%	24%	0%	1
ИИ + проверка запуском	80%	80%	12%	0%	1

Интеграции

Внешние системы подключены через одну точку и по умолчанию заменены встроенными моками. Переключение на реальную систему делается переменными окружения, код при этом не меняется.

FSP ID и достижения ФСП

Вход через FSP ID работает по OIDC с PKCE: discovery, обмен кода на токены, проверка ID-токена по JWKS. Профиль кандидата связывается с ID участника, после чего достижения подтягиваются в профиль.

По умолчанию используется встроенный мок по адресу `{PUBLIC_BASE_URL}/mock/fsp`. Переход на настоящий Keycloak ФСП делается только этими переменными:

- `FSP_ID_ISSUER` — issuer реального FSP ID;
- `FSP_ID_CLIENT_ID`, `FSP_ID_CLIENT_SECRET` — клиент;
- `FSP_API_URL` — API достижений;
- `MOCKS_ENABLED=false` — выключить моки.

Один FSP ID нельзя привязать к двум аккаунтам: ограничение на пару «issuer и subject» держится в базе. Случай, когда истории ФСП у кандидата нет, обрабатывается явно: профиль показывает статус «нет результатов».

DaData

Проверка юрлица по ИНН для уровня доверия L2. По умолчанию мок возвращает компанию для любого корректного ИНН. Реальный адрес и токен задаются переменными `DADATA_URL` и `DADATA_TOKEN`.

ATS компании

Работодатель может получать события по приглашениям и этапам найма на свой адрес. Доставка идёт через outbox: событие пишется в той же транзакции, что и действие, а worker доставляет его с повторами.

- Формат: Standard Webhooks. Заголовки `webhook-id`, `webhook-timestamp`, `webhook-signature`, подпись HMAC-SHA256 по строке «id, timestamp, тело».
- Повторы по расписанию, после исчерпания попыток доставка помечается как неуспешная.
- Защита от SSRF: только https и публичный адрес, проверка при создании и перед каждой отправкой, редиректы не выполняются.
- В событии только псевдоним кандидата и ссылки, без ФИО и контактов.
- Для демонстрации есть встроенный мок ATS со страницей принятых событий.

Пример проверки подписи на стороне получателя:

```
import base64, hashlib, hmac

def verify(secret: str, msg_id: str, timestamp: str, body: str, signature: s
    key = base64.b64decode(secret.removeprefix("whsec_"))
    expected = "v1," + base64.b64encode(
```

```
        hmac.new(key, f"{msg_id}.{timestamp}.{body}".encode(), hashlib.sha25
    ).decode()
    return any(hmac.compare_digest(expected, part) for part in signature.spl
```

Почта

Письма отправляет worker: подтверждение почты, напоминания, ссылка согласия законного представителя. Для демо используется Mailpit. Без заданного `MAIL_HOST` письма только пишутся в журнал, что удобно локально.

Персональные данные и согласия

Что собираем и зачем

- **Аккаунт.** Почта, роль, дата рождения (для юниорского трека). Почта подтверждается.
- **Профиль кандидата.** Направление и грейд, стек, условия и контакты. Контакты видит работодатель только после того, как кандидат принял приглашение или откликнулся сам.
- **Результаты.** Попытки теста, навыки, достижения ФСП.
- **Работодатель.** Данные компании и уровень доверия.

Назначение каждого поля и сроки хранения зафиксированы в политике обработки.

Согласия

Согласия выдаются и отзываются явно, каждое со своей версией текста:

- **Обработка персональных данных.** Базовое согласие при регистрации.
- **Распределение профиля.** Что именно видят работодатели: имя и контакты скрыты всегда, видимость остальных полей задаётся пресетом.
- **Автоматические правила.** До первого теста кандидат соглашается с автоматическим решением по итогу.
- **Передача контактов.** Отдельное согласие на конкретную компанию при принятии приглашения.
- **Согласие законного представителя.** Для кандидатов 14–17 лет профиль остаётся черновиком до согласия.

Тексты согласий:

Согласие на обработку персональных данных (редакция 2026-10-07-0b4b65c3)

Оператор платформы обратного найма ИТ-специалистов (демонстрационный стенд ЛЦТ 2026) обрабатывает ваши персональные данные: адрес электронной почты, год рождения, сведения профиля (специализация, стек, опыт, условия работы), результаты тестов и сведения о достижениях ФСП (если вы привяжете FSP ID). Цели: регистрация и вход, определение категории по результатам теста, подбор и связь с работодателями по вашему решению. Действия: сбор, запись, хранение на серверах в РФ, уточнение, использование, обезличивание, удаление. Срок: до отзыва согласия или удаления аккаунта. Отозвать согласие можно в настройках; данные будут удалены в течение 30 дней.

Согласие на распространение данных профиля (ст. 10.1 152-ФЗ) (редакция 2026-10-07-826f167f)

Вы разрешаете показывать зарегистрированным работодателям платформы выбранные поля профиля в псевдонимном виде (без ФИО и контактов): категорию и грейд, подтверждённые навыки, стек, опыт, формат работы, город, достижения ФСП. ФИО и контакты не распространяются: работодатель получает их только после того, как вы примете его приглашение и дадите отдельное согласие. Условие: без передачи третьим лицам. Набор полей можно изменить, а согласие отозвать в настройках приватности. После отзыва профиль скрывается сразу.

Согласие с автоматическими правилами платформы (ст. 16 152-ФЗ) (редакция 2026-10-07-ed12f83f)

Грейд подтверждается автоматически по результатам теста. Порядок в выдаче для работодателя рассчитывается автоматически по результатам теста, подтверждённым навыкам, достижениям ФСП и подтверждениям на собеседованиях; оценки ниже ожиданий не опускают профиль ниже нейтрального уровня и не видны работодателям. Между попытками действуют паузы. Тест на тот же грейд можно повторить через 30 дней, тест на грейд выше можно пройти через 90 дней после подтверждения. Окончательное решение о найме всегда принимает человек. Вы можете оспорить решение через форму обращения. Мы ответим не позднее чем через 30 дней.

Согласие на передачу контактов компании (редакция 2026-10-07-fe4c62d3)

Вы разрешаете передать ваши ФИО и контакты компании, приглашение которой принимаете (или на вакансию которой откликаетесь), для связи по этому предложению. После передачи компания становится самостоятельным оператором ваших данных. Вы

можете скрыть контакты на платформе в любой момент. Компания получит уведомление об отзыве согласия.

Согласие законного представителя несовершеннолетнего (ст. 9, 10.1 152-ФЗ)
(редакция 2026-10-07-9c92e39a)

Я, законный представитель (родитель, усыновитель или опекун) несовершеннолетнего пользователя 14–17 лет, даю согласие на обработку его персональных данных на платформе обратного найма и на показ его профиля работодателям в псевдонимном виде только в потребностях «стажировка» и «каникулярная работа». ФИО и контакты работодатель получает только после принятия приглашения. Работа возможна в пределах ст. 92 ТК РФ: до 24 часов в неделю в 14–15 лет и до 35 часов в 16–17 лет в каникулы; в учебный год не больше 50% от этих значений. Согласие можно отозвать, написав нам; профиль несовершеннолетнего после отзыва снова станет черновиком.

Защита данных перед моделью

Перед отправкой в модель текст маскируется: почта, телефон, ссылки, ник, дата рождения, длинные номера и ФИО заменяются метками. Данные кандидата идут только к моделям с размещением данных в России. Если NER выключен или не отработал, текст резюме в модель не отправляется.

Юниорский трек

Для кандидатов 14–17 лет профиль становится видимым только после согласия законного представителя. Доступны стажировка и каникулярная работа, часы ограничены Трудовым кодексом. Для полной занятости такие кандидаты не показываются.

Права кандидата

- **Возражение против автоматического решения.** По ст. 16 152-ФЗ кандидат может возразить против решения по итогу теста. Возражение уходит модератору, срок ответа до 30 дней, ответ приходит в раздел «Мои обращения».
- **Отзыв согласия и удаление.** Кандидат может отвязать FSP ID и скрыть данные ФСП, скрыть компанию, отозвать согласие на передачу контактов.

Безопасность

Пароли хранятся через argon2, токены подтверждения и сессий хранятся в виде хешей и одноразовые. Доступ ограничен ролями и проверкой владения объектом. Подробнее — в `docs/security.md`.

Языковая модель

Модель подключается через OpenAI-совместимый API (по умолчанию провайдер Polza.ai, переменная `LLM_BASE_URL`). Ключ задаётся в `LLM_API_KEY`. Без ключа продукт продолжает работать.

Где используется

- **Разбор резюме.** PDF превращается в черновик профиля: стек, опыт, формат, город. Кандидат проверяет и подтверждает.
- **Разбор текста потребности.** Свободный текст вакансии превращается в структуру: специализация, грейды, стек, вилка.
- **Перефразирование объяснений.** Строки объяснения в подборке звучат естественно. Числа и технологии сверяются с фактами карточки, выдуманное отбрасывается.
- **Подсказка к решению задачи.** Работодатель получает совет по ответу кандидата. Решение остаётся за ним.
- **Лаборатория.** Офлайн-проверка ключей банка двумя моделями и судья подбора на синтетике.

Где работает без модели

Во всех сценариях есть запасной путь: разбор резюме и потребности по правилам и словарю, объяснения по шаблону, вердикты по вычисляемому ключу. Модель улучшает форму, но не держит логику.

Маршруты и данные

Режим задаётся `LLM_PROFILE`:

- **dev** — только синтетика, данные кандидата не используются;
- **prod** — развёрнутый стенд, где может быть настоящее резюме; тогда данные кандидата идут только к моделям с размещением в России (GigaChat, запасной

вариант YandexGPT).

Модель выбирается отдельно под задачу. При старте конфигурация проверяется: если в prod для данных кандидата назначена иностранная модель, старт останавливается.

Надёжность

- **Маскирование.** Персональные данные заменяются метками до отправки. Если маскирование неполное, текст в модель не уходит.
- **Один повтор.** Ответ модели валидируется по схеме, при ошибке делается один повтор, затем включается фолбэк.
- **Circuit breaker.** После нескольких ошибок вызовы на время прекращаются, сценарий уходит на запасной путь.
- **Без фоновых вызовов.** Модель вызывается только там, где человек ждёт ответа.

Стоимость прогонов лаборатории: офлайн-задачи считаются по ключу, обычный прогон на странице лаборатории идёт без обращения к модели.

Сборка и запуск

Локально

Нужны Python 3.12 через `uv`, Node и `pnpm`. Локальная база поднимается встроенным PostgreSQL из пакета `pgserver`, отдельный сервер не нужен.

```
make devdb          # поднять встроенную базу и напечатать DATABASE_URL
make initdb         # схема
make seed           # демо-данные: около 450 синтетических кандидатов и демо
make api            # бэкенд на :8000
make worker         # фоновые задачи: письма, напоминания, вебхуки
make web            # фронтенд на :5173
```

Проверки:

```
make test           # тесты бэкенда и фронтенда
make lint           # ruff
make bank-check     # проверка всех семейств банка
```

```
make validate       # лаборатория, полный отчёт в reports/validation.json
make openapi        # экспорт openapi.json в docs/api
make docs           # сборка документов и генерируемых частей
```

Через Докер

```
make up             # локальный стенд, наружу порт 8080
make down           # остановить
make smoke URL=http://localhost:8080
```

Развёртывание на сервере

- **Свой домен и HTTPS.** `sudo bash deploy/bootstrap.sh`. Скрипт ставит Докер, генерирует пароль базы и секрет сессий, собирает и запускает стенд, проверяет его смоук-тестом. Подробности — в `deploy/README.md`.
- **Сервер уже занят другими приложениями.** Тот же стек запускается за вашим прокси хоста: наружу открывается только `127.0.0.1:APP_PORT`, порты 80 и 443 остаются за прокси. Команда и пример конфигурации nginx — в `deploy/README.md`, разбор безопасности — в `docs/security.md`.

Переменные окружения

Шаблон — в `.env.example`. Основное:

- `DATABASE_URL`, `SECRET_KEY` — подключение к базе и секрет сессий;
- `DEMO_MODE`, `MOCKS_ENABLED` — демо-персоны и встроенные моки;
- `PUBLIC_BASE_URL`, `COOKIE_SECURE` — публичный адрес и защищённая cookie;
- `LLM_PROFILE`, `LLM_BASE_URL`, `LLM_API_KEY` — модель;
- `FSP_ID_ISSUER`, `FSP_ID_CLIENT_ID`, `FSP_ID_CLIENT_SECRET`, `FSP_API_URL` — переход на реальный FSP ID.

Требования к машине

Специальное оборудование не нужно. Контейнеры ограничены по памяти и вместе укладываются в 1,5 ГБ: база, API, worker, веб-сервер и почта. Продукт работает и без ключа модели.

Безопасность и развёртывание

Документ отвечает на два вопроса: что в системе защищено, и как безопасно поднять экземпляр на сервере, где уже работают другие приложения.

Важно понимать контекст: этот экземпляр демонстрационный, для жюри. Демо-режим и встроенные моки включены намеренно. Ниже описано, что из этого следует и как изолировать стенд.

Что включено намеренно

- `DEMO_MODE=true` открывает переключатель персон: вход под демо-кандидата, работодателя и модератора (`POST /api/v1/demo/login-as`). Это нужно жюри, чтобы пройти сценарии без регистрации.
- Вместе с демо-режимом включаются встроенные моки внешних систем: FSP ID (`/mock/fsp`), API достижений, DaData (`/mock/dadata`), ATS (`/mock/ats`). Мок FSP ID принимает вход с паролем `demo` и известным клиентским секретом.
- Документация API открыта: `/api/v1/openapi.json`, `/api/v1/docs`, `/api/v1/redoc`. Жюри этим пользуется.

Из этого следует главное правило: стенд не должен быть доступен всему интернету. Доступ ограничивается сетью и прокси, а не отключением демо.

Что исправлено в коде

- **SSRF через вебхуки.** Сервер переписывает адрес публичного origin платформы на внутренний (`FSP_SERVER_BASE`). Обычный вебхук на этот origin теперь отклоняется, кроме адреса встроенного мока ATS (`app/integrations/webhooks.py`, функция `check_url`). Проверка стоит и при создании вебхука, и перед каждой отправкой.
- **Изоляция подпроцессов.** Разбор PDF, NER и исполнение SQL на данных кандидата идут в подпроцессах с пределами по памяти, процессорному времени, размеру файла и числу процессов. Из окружения подпроцесса убраны переменные с секретами (`app/common/subproc.py`, `safe_env`, `child_limits`). Раньше сбой нативной библиотеки PDF оставлял в процессе доступ к базе, ключу LLM и сети.
- **Маскирование ПДн перед LLM.** Длинные номера без контрольной суммы (паспорт, водительское) теперь тоже маскируются (`app/llm/masking.py`). Если NER выключен, маскирование считается неполным и текст резюме в LLM не уходит (`app/llm/names.py`, `scan_names`). По умолчанию NER включён.

- **Секрет по умолчанию.** В боевом режиме старт останавливается, если `SECRET_KEY` не задан или остался значением по умолчанию (`app/config/settings.py`, `validate_secrets`). От секрета зависит выбор заданий в тесте.

Осознанно оставленные риски

- **Запуск прогона лаборатории** (`POST /api/v1/lab/runs`) доступен любому вошедшему пользователю и нагружает процессор на минуты (`app/lab/router.py`). Одновременно идёт только один прогон, зависшие снимаются. На демо это допустимо; на открытом инстансе ограничьте ролью или доступом на уровне прокси.
- **Нет троттлинга входа и регистрации.** Возможен перебор пароля и рассылка писем через регистрацию (`app/auth/router.py`). Для демо, закрытого прокси, риск низкий; для открытого инстанса добавьте лимиты на уровне прокси или в приложении.
- **Прогон теста не прерывается за уход со вкладки.** Это принцип продукта: сигналы честности сохраняются, но не наказывают. Модель угроз описана на странице «Модель угроз».
- **DNS-проверка вебхука и подключение идут разными резолвами** (теоретический DNS rebinding). Смягчено тем, что вебхуки не могут указывать на сам сервис и во внутренние адреса, а редиректы запрещены.

Чек-лист безопасного развёртывания рядом с другими приложениями

1. **Порты.** Запускать стек с оверлеем `deploy/docker-compose.shared.yml`: наружу открыт только `127.0.0.1:APP_PORT`, порты 80 и 443 не занимаются. Проверить: `ss -ltnp | grep 8080` показывает 127.0.0.1.
2. **Прокси хоста.** Направить домен на `http://127.0.0.1:APP_PORT`. Заголовки безопасности (HSTS, X-Content-Type-Options, X-Frame-Options, Referrer-Policy) выставить на прокси. Пример nginx есть в `deploy/README.md`.
3. **Доступ.** Ограничить стенд: базовый HTTP-аутентификация на прокси, allowlist IP жюри или VPN. Демо отдаёт вход модератором всем, кто дошёл до сервиса.
4. **Секреты.** `SECRET_KEY`, `POSTGRES_PASSWORD` и ключ LLM держать только в `.env` с правами 600. В боевом режиме старт с секретом по умолчанию не пройдёт.
5. **Cookie.** `COOKIE_SECURE=true` и публичный адрес по HTTPS. Без этого cookie сессии уйдёт в открытом виде.

6. **Сеть контейнеров.** Стек живёт в своей сети `fsp2026-shared`. Если нужно запретить контейнерам ходить на другие порты хоста, ограничьте исходящие соединения средствами Докера или firewall.
7. **База.** Порт PostgreSQL наружу не публикуется, доступ только из сети стека. Пароль БД генерируется `bootstrap.sh`.
8. **Обновление.** `git pull` и повторный запуск `up -d --build --wait`. Данные в томе сохраняются, схема обновляется миграциями при старте.
9. **Резервная копия.** `docker compose exec -T db pg_dump -U fsp fsp | gzip > backup-$(date +%F).sql.gz`.

Что уже сделано хорошо

- Контейнеры без root, без docker.sock, без привилегированных режимов; лимиты памяти и healthcheck на каждом сервисе.
- Сессии: httpOnly-cookie, `SameSite=Lax`, токен хранится хешем, есть срок жизни и отзыв. Пароли через argon2.
- CSRF: обязательный заголовок на изменяющих запросах плюс `SameSite`. Есть проверки владения объектом на всех межаккаунтных чтениях и записях.
- Токены подтверждения, восстановления и согласия опекуна: 256 бит, хранятся хешем, одноразовые, с ограниченным сроком.
- Секреты не пишутся в журналы. События аудита фиксируют просмотр контактов и переключение персон.